Detecting DCSync Attacks with Wazuh

Building and validating a custom detection rule for Active Directory credential replication

MITRE ATT&CK T1003.006 · OS Credential Dumping: DCSync

Deliverable	Security lab report
Environment	VirtualBox host-only lab (CORP.LOCAL)
SIEM	Wazuh 4.x (manager + indexer + dashboard)
Attacker tool	Impacket secretsdump (v0.14.0.dev0)
Author	Shariff Mohamud Goow
Date	10 September 2026

Contents

1 Objective
2 Lab environment
3 Background: the DCSync technique
4 Methodology
5 Detection rule design
6 Attack execution
7 Results
8 Analysis
9 MITRE ATT&CK mapping
10 Limitations and next steps
11 Conclusion
References
Appendix A — Final ruleset (local_rules.xml)
Appendix B — Key decoded event fields

1 Objective

This report documents the design, implementation and validation of a custom Wazuh detection rule for the DCSync attack. The goal was to detect, in real time, when a non-domain-controller account exercises Active Directory replication rights to extract credential material from a domain controller — the technique catalogued by MITRE ATT&CK as T1003.006.

The exercise had three success criteria: **(i)** generate the relevant Windows audit event (4662) on the domain controller and forward it to Wazuh; **(ii)** author a rule that fires only on genuine replication-rights requests rather than on routine directory access; and **(iii)** confirm end-to-end detection by executing a live DCSync attack and observing the resulting alert in the dashboard.

Result: all three criteria were met. A level-12 alert (rule 100100) fired on the live attack, mapped to T1003.006, and correctly distinguished the malicious request from several hundred benign 4662 events in the same window.

2 Lab environment

The lab runs entirely within Oracle VirtualBox on a single host, using an isolated host-only network (192.168.56.0/24). Three guest machines participate in the detection scenario; the Windows host is used only as a dashboard viewer.

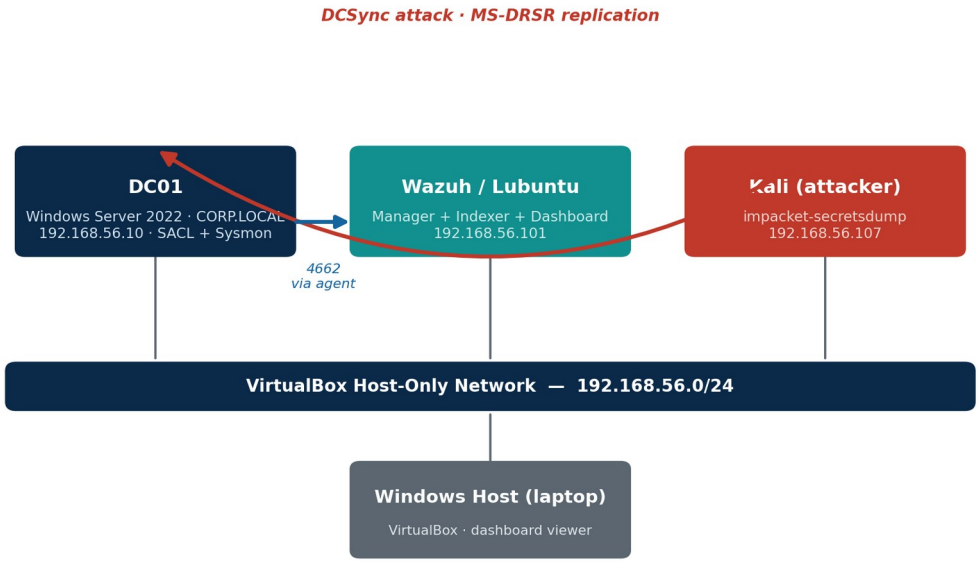


Figure 1 — Lab topology and data flow. Kali performs the DCSync attack against DC01; DC01 forwards audit event 4662 to the Wazuh manager via its agent.

Host	Address	Role	Relevant configuration
DC01	192.168.56.10	Domain controller	Windows Server 2022, CORP.LOCAL; audit SACL on the domain object; Sysmon; Wazuh agent (id 001)
Wazuh / Lubuntu	192.168.56.101	SIEM	Ubuntu 20.04.6 LTS; Wazuh manager, indexer and dashboard (native install)
Kali	192.168.56.107	Attacker	Impacket secretsdump v0.14.0.dev0
Windows host	—	Analyst workstation	Runs VirtualBox; views the dashboard over the host-only network

Note on auditing. DCSync detection depends on a System Access Control List (SACL) applied to the domain object so that replication access generates event 4662. This auditing is disabled by default in Active Directory; enabling it is a prerequisite, not an assumption (Microsoft, 2021).

3 Background: the DCSync technique

Active Directory keeps domain controllers consistent by replicating directory data — including password material — between them using the Directory Replication Service Remote Protocol (MS-DRSR). DCSync abuses this legitimate mechanism: an attacker holding the necessary replication rights impersonates a domain controller and asks a real DC to "replicate" secrets to them, retrieving NTLM hashes and Kerberos keys — including those of the krbtgt account — without ever running code on the DC or touching LSASS (The MITRE Corporation, 2021; Metcalf, 2015).

Because the request travels over a sanctioned protocol, the signal that separates attack from routine replication is narrow: the presence of specific replication extended-rights GUIDs combined with a requesting account that is not a domain controller. The three replication rights that matter are (NCC Group, 2024; Microsoft, 2021):

Extended right (GUID)	Meaning
`1131f6aa-9c07-11d1-f79f-00c04fc2dcd2`	DS-Replication-Get-Changes
`1131f6ad-9c07-11d1-f79f-00c04fc2dcd2`	DS-Replication-Get-Changes-All
`89e95b76-444d-4c62-991a-0facbeda640c`	DS-Replication-Get-Changes-In-Filtered-Set

4 Methodology

Detection was assembled as a pipeline from attacker action to analyst alert. Each stage was verified before moving to the next, which is what allowed the final failure (see §7) to be isolated quickly.



Figure 2 — The detection pipeline, from the attacker's replication request to the indexed alert.

4.1 Configuration steps

- **Audit SACL.** A SACL (Everyone / Success / read-access) was applied to the domain object and its descendants so that replication access generates event 4662; confirmed generating in the DC01 Event Viewer.
- **Telemetry.** Sysmon was installed on DC01 and the Wazuh agent configured to forward the Windows Security channel; the agent showed Active on the manager.
- **Baseline.** A clean pre-attack snapshot ("detection-baseline") of DC01 was preserved.
- **Custom rule.** Rules 100100/100101/100199 were added to local_rules.xml and loaded via a manager restart (§5).

5 Detection rule design

The detection is expressed as three rules chained from the Wazuh Windows-security parent rule (60103). Rule 100100 is the detection; 100101 suppresses legitimate machine-account replication; 100199 is a temporary diagnostic used to prove the event was arriving (removed after validation). The chaining structure and machine-account suppression follow the approach documented by Wazuh (2024).

```
<group name="dcsync_local,">
  <rule id="100100" level="12">
    <if_sid>60103</if_sid>
    <field name="win.system.eventID">^4662$</field>
    <field name="win.eventdata.properties" type="pcre2">1131f6aa-9c07-11d1-f79f-
        00c04fc2dcd2|1131f6ad-9c07-11d1-f79f-00c04fc2dcd2|89e95b76-444d-4c62-
        991a-0facbeda640c</field>
    <description>Possible DCSync attack: replication rights requested
(4662)</description>
    <group>attack,dcsync,mitre_t1003_006,</group>
  </rule>

  <rule id="100101" level="0">
    <if_sid>100100</if_sid>
    <field name="win.eventdata.SubjectUserName" type="pcre2">\$$</field>
    <description>Legitimate replication from machine account -
suppressed</description>
  </rule>
</group>
```

5.1 Rule 100100 field by field

Condition	Purpose
`if_sid = 60103`	Chains from the Wazuh parent rule for the Windows Security event channel, so the rule only evaluates decoded Security events.
`eventID = ^4662$`	Restricts to “an operation was performed on an AD object” — the event DCSync produces on the DC.
`properties = (GUID|GUID|GUID)`	The core signal: a PCRE2 match requiring one of the three replication-rights GUIDs in the event's properties field. This is what separates DCSync from ordinary directory reads.
`level = 12`	High-severity classification, surfacing the alert in the dashboard's critical band.

Design choice — suppression by account type. Rule 100101 drops any matching event whose SubjectUserName ends in “$” (i.e. a machine account), because legitimate DC-to-DC replication is performed by computer accounts. A DCSync attack run as an ordinary user does not end in “$”, so it still fires. This account-type distinction is the second half of the detection logic and the reason the rule is precise rather than noisy.

6 Attack execution

From Kali, DCSync was executed against DC01 using Impacket's secretsdump (Fortra, 2023) with a compromised domain user (VBOXUSER) holding replication rights:

```
impacket-secretsdump 'CORP.LOCAL/VBOXUSER:<password>@192.168.56.10' -just-dc
```

The attack succeeded, replicating credential material for domain users and machine accounts (sjones, Mtaylor, the svc-sql service account, and the DC01$/WRK01$/WRK02$ machine accounts), ending with a clean “Cleaning up…”.

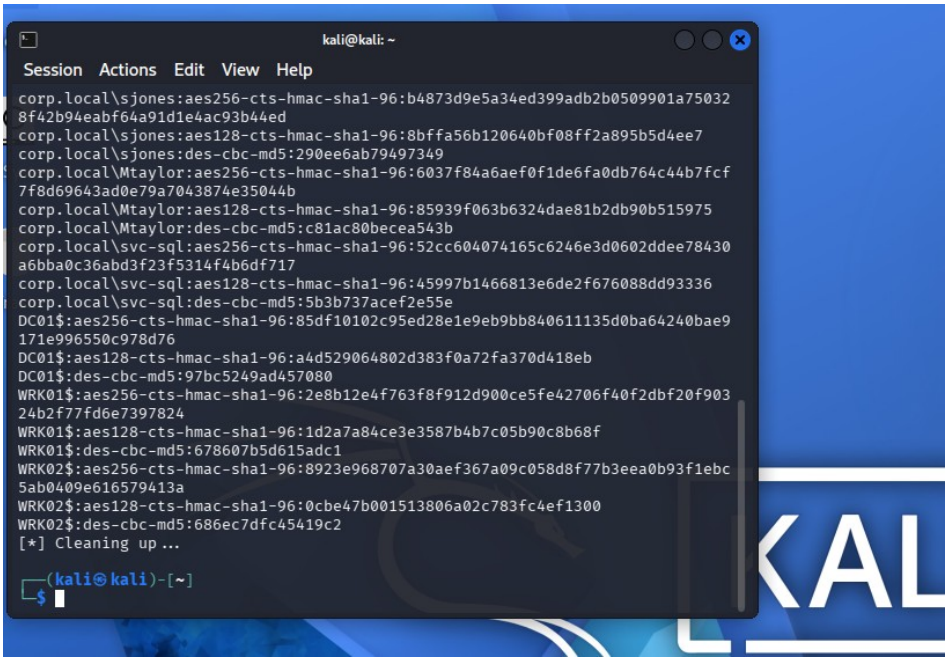


Figure 3 — Successful DCSync from Kali: replicated Kerberos keys and machine-account hashes dumped over MS-DRSR.

7 Results

Immediately after the attack, the Threat Hunting view returned **10 hits** for rule 100100 (“Possible DCSync attack”, level 12) from agent DC01.

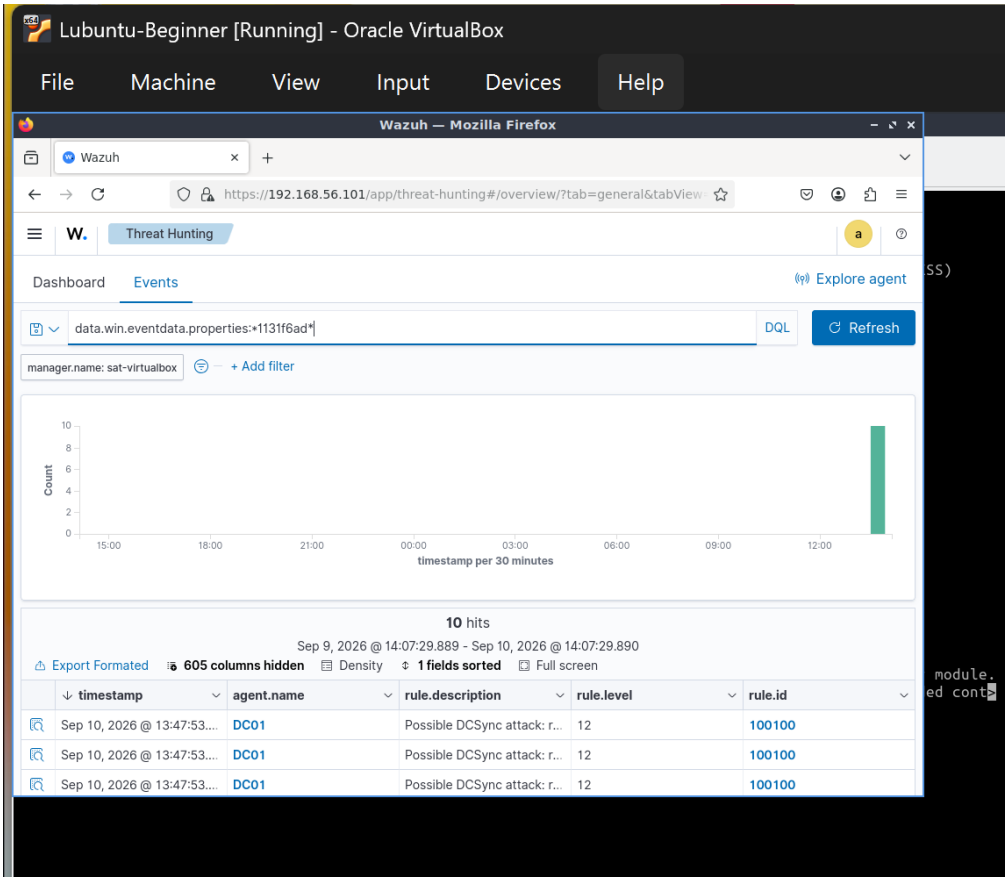


Figure 4 — Rule 100100 firing: ten level-12 DCSync alerts from DC01, filtered on the DS-Replication-Get-Changes-All GUID.

Expanding a single alert confirmed the decoded event data. The requesting identity is a user SID ending in RID 1000 (VBOXUSER) in domain CORP — not a machine account — which is precisely the condition the detection is designed to catch.

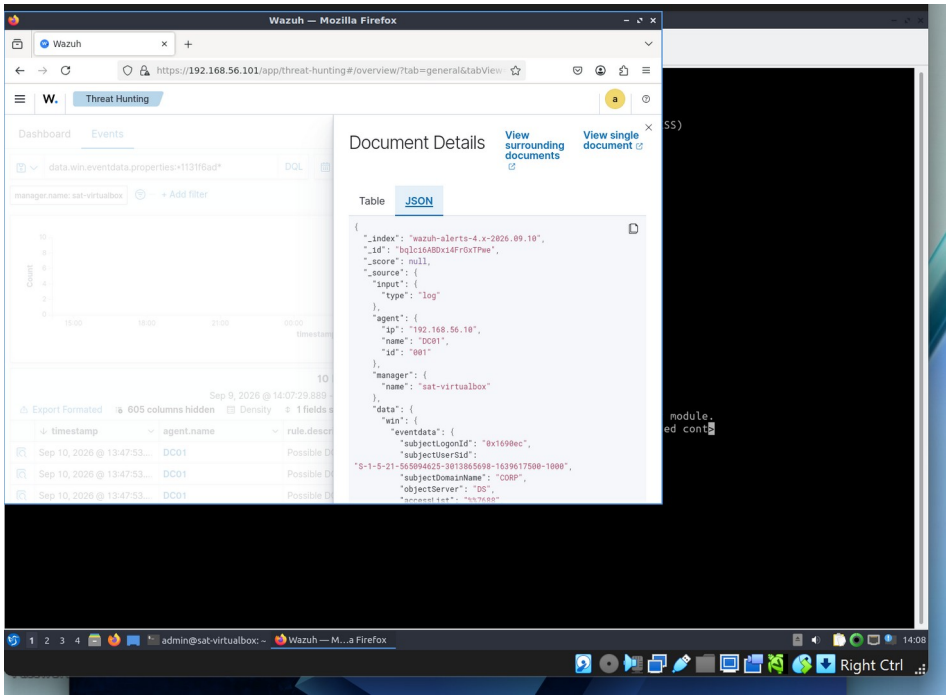


Figure 5 — Decoded alert (JSON). Agent DC01 / 192.168.56.10; subjectUserSid ends in …1000 (a user, not a DC).

The manager was confirmed healthy throughout, with the rules loaded and the analysis daemon running.

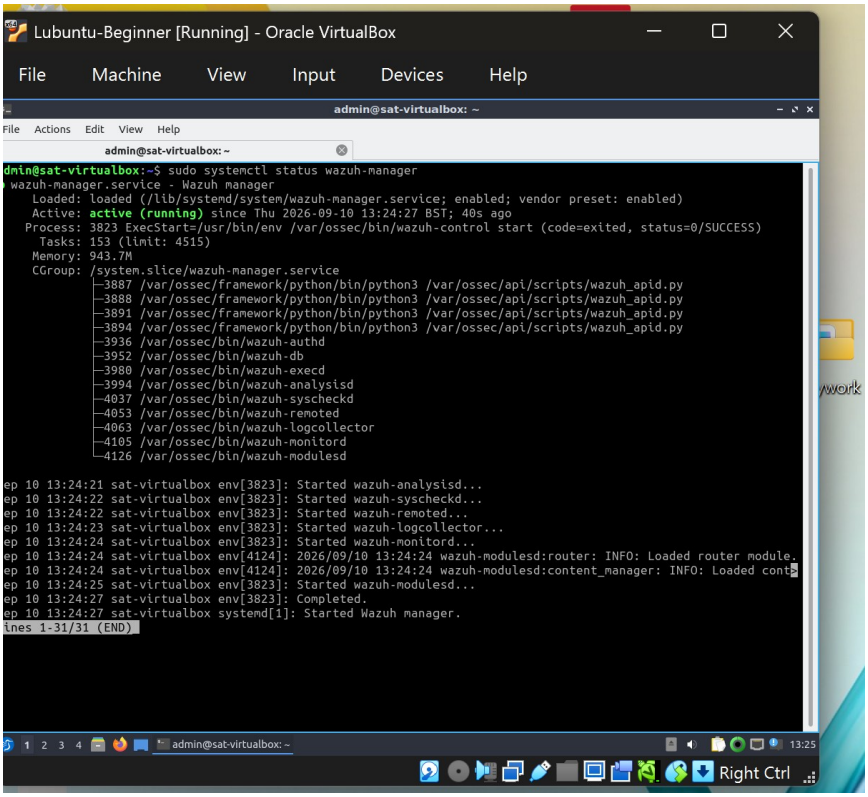


Figure 6 — Wazuh manager active (running) with wazuh-analysisd and the agent listener up after loading the custom rules.

8 Analysis

8.1 Signal versus noise

Event 4662 is high-volume: routine directory access produced 777 such events in the short observation window. Only the ten carrying a replication-rights GUID from a non-machine account were the attack. This ratio is the central justification for the rule's GUID + account-type filtering — alerting on raw 4662 would bury the attack in noise and be operationally useless.

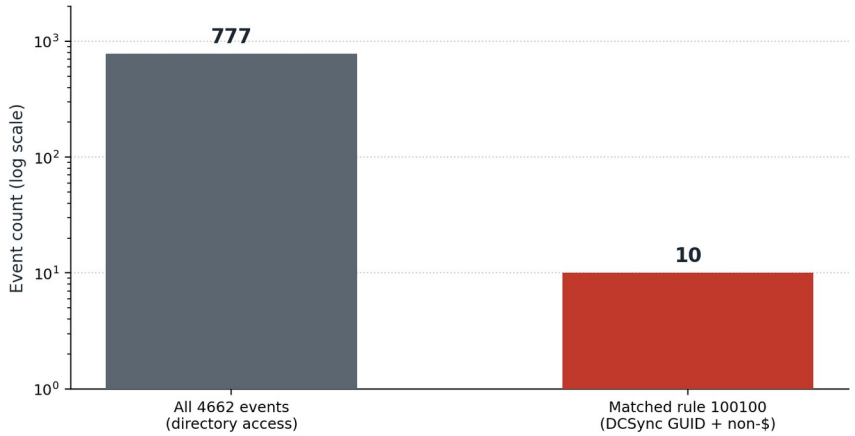


Figure 7 — Of 777 4662 events in the window, only 10 matched the DCSync signature (log scale).

8.2 A validation lesson

During validation, the first 4662 event inspected did not match rule 100100. Inspection of its decoded fields showed an access mask of 0x10 (read property) and object/property GUIDs unrelated to replication — i.e. benign directory access, correctly excluded. The genuine DCSync events, carrying access mask

0x100 and the DS-Replication-Get-Changes-All GUID, were separate rows in the same batch and had matched 100100 all along. The apparent failure was an inspection of the wrong event, not a rule defect — a useful reminder that 4662 must be filtered on both access mask/GUID and account type before conclusions are drawn.

9 MITRE ATT&CK mapping

The detection maps to the following MITRE ATT&CK classification (The MITRE Corporation, 2021):

Attribute	Value
Tactic	TA0006 — Credential Access
Technique	T1003.006 — OS Credential Dumping: DCSync
Data source	Windows Security event 4662 (Directory Service Access) via audit SACL
Detection logic	Replication-rights GUID present AND requesting account is not a machine account ($)
Rule / severity	local rule 100100 / level 12

10 Limitations and next steps

- **Source attribution.** A single 4662 does not reveal the origin of the request. Correlating it with logon event 4624 (Logon Type 3) by Logon ID would attribute the attack to a source IP — a natural enhancement.
- **Suppression testing.** Rule 100101 suppresses machine-account replication, but a single-DC lab produces little legitimate DC-to-DC replication to exercise it against; this should be validated in a multi-DC environment.
- **Diagnostic rule.** Rule 100199 was a temporary aid and should be removed from the production ruleset (it fires on all 4662).
- **Next technique.** Pass-the-Hash detection (using the material dumped here) is the planned follow-on, time-boxed after this result.

11 Conclusion

A precise, real-time DCSync detection was implemented and validated end to end in Wazuh. The rule correctly identifies replication-rights abuse by a non-domain-controller account, maps cleanly to MITRE T1003.006, and isolates the attack from several hundred benign directory-access events in the same window. This satisfies the highest-value objective of the lab and provides a documented, reproducible detection suitable for inclusion in the dissertation.

References

Formatted in APA (7th ed.) author–date style, as produced by Google Scholar's "Cite" tool. Access dates should be added per your institution's convention.

Fortra. (2023). *Impacket* [Computer software]. GitHub. https://github.com/fortra/impacket

Metcalf, S. (2015). *Mimikatz DCSync usage, exploitation, and detection*. Active Directory Security. https://adsecurity.org/?p=1729

Microsoft. (n.d.). *[MS-DRSR]: Directory Replication Service (DRS) Remote Protocol*. Microsoft Learn. https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-drsr/

Microsoft. (2021). *4662(S, F): An operation was performed on an object*. Microsoft Learn. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4662

NCC Group. (2024). *Defending your directory: An expert guide to securing Active Directory against DCSync attacks*. NCC Group Research. https://www.nccgroup.com/research/defending-your-directory-an-expert-guide-to-securing-active-directory-against-dcsync-attacks/

The MITRE Corporation. (2021). *OS credential dumping: DCSync (T1003.006)* [Sub-technique]. MITRE ATT&CK. https://attack.mitre.org/techniques/T1003/006/

Wazuh. (n.d.). *Ruleset XML syntax*. Wazuh Documentation. https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/index.html

Wazuh. (2024). *How to detect Active Directory attacks with Wazuh (Part 1 of 2)*. Wazuh Blog. https://wazuh.com/blog/how-to-detect-active-directory-attacks-with-wazuh-part-1-of-2/

Appendix A — Final ruleset (local_rules.xml)

As deployed; rule 100199 is shown for completeness and is recommended for removal from production.

```
<group name="dcsync_local,">
  <rule id="100100" level="12">
    <if_sid>60103</if_sid>
    <field name="win.system.eventID">^4662$</field>
    <field name="win.eventdata.properties" type="pcre2">1131f6aa-...|1131f6ad-...|
89e95b76-...</field>
    <description>Possible DCSync attack: replication rights requested
(4662)</description>
    <group>attack,dcsync,mitre_t1003_006,</group>
  </rule>
  <rule id="100101" level="0">
    <if_sid>100100</if_sid>
    <field name="win.eventdata.SubjectUserName" type="pcre2">\$$</field>
    <description>Legitimate replication from machine account -
suppressed</description>
  </rule>
  <rule id="100199" level="5">
    <if_sid>60103</if_sid>
    <field name="win.system.eventID">^4662$</field>
    <description>DIAG: raw 4662 (remove after field-name check)</description>
  </rule>
</group>
```

Appendix B — Key decoded event fields

Field	Observed value / significance
`agent.name / agent.ip`	DC01 / 192.168.56.10 — event sourced from the domain controller
`win.system.eventID`	4662 — Directory Service Access
`win.eventdata.accessMask`	0x100 (Control Access) on the DCSync events; 0x10 (read) on benign ones
`win.eventdata.properties`	Contains {1131f6ad-…} DS-Replication-Get-Changes-All
`win.eventdata.subjectUserName`	VBOXUSER — a user account (SID RID 1000), not a machine ($) account
`rule.id / rule.level`	100100 / 12; MITRE tag mitre_t1003_006